

Template injection to arbitrary code execution #4394

 Closed

 #10252

r3pwnx opened on May 9, 2023 · edited by r3pwnx

Edits ▾ ⋮

System Info

windows 11

Who can help?

No response

Information

- ☒ The official example notebooks/scripts
- ☐ My own modified scripts

Related Components

- ☐ LLMs/Chat Models
- ☐ Embedding Models
- ☒ Prompts / Prompt Templates / Prompt Selectors
- ☐ Output Parsers
- ☐ Document Loaders
- ☐ Vector Stores / Retrievers
- ☐ Memory
- ☐ Agents / Agent Executors
- ☐ Tools / Toolkits
- ☐ Chains
- ☐ Callbacks/Tracing
- ☐ Async

Reproduction

1. save the following data to pt.json

2. run

3. the `dir` command will be execute

attack scene: Alice can send prompt file to Bob and let Bob to load it.

analysis: Jinja2 is used to concat prompts. Template injection will happened

note: in the pt.json, the `template` has payload, the index of `__subclasses__` maybe different in other environment.

Expected behavior

code should not be execute

Author ...

The index of "**subclasses**" can be obtained in the following way.




 **dosubot** added **stale** on Aug 30, 2023

 **obi1kenobi** removed **stale** on Aug 30, 2023

 obi1kenobi on Aug 30, 2023

Collaborator ...

Sorry for the bot reply, it's still a beta and shouldn't be attempting to close security-related issues like this. I'm triaging this right now and should have an update shortly.

 obi1kenobi on Aug 30, 2023

Collaborator ...

Issue confirmed, escalating to `security@langchain.dev`.

Apologies for the delay here. This issue slipped through the cracks, which should not have happened. We're going to use this instance as an internal case study to make sure we do way better in the future.

We've already added a `SECURITY.md` to the repo so that GitHub directs users to send security-related information to `security@langchain.dev` to ensure any security-related issues are promptly acted upon: [#9551](#)

We're also looking at automation to help us detect security-related issues opened on public GitHub, so we can more effectively internally escalate it to `security@langchain.dev` as well.

  **obi1kenobi** mentioned this on Sep 6, 2023

 [Disable loading jinja2 PromptTemplate from file. #10252](#)

  **obi1kenobi** added a commit that references this issue on Sep 6, 2023

Disable loading jinja2 `PromptTemplate` from file. ...

 b574d72

  **obi1kenobi** closed this as completed in [#10252](#) on Oct 10, 2023

  **obi1kenobi** added a commit that references this issue on Oct 10, 2023

Disable loading jinja2 `PromptTemplate` from file. ([#10252](#)) ...

 **Verified** 22abeb9

  **aymeric-roucher** mentioned this on Dec 6, 2023

 [Specific prompt adds false input variables #14343](#)

  **hoanq1811** added a commit that references this issue on Feb 2, 2024

Disable loading jinja2 `PromptTemplate` from file. ([langchain-ai#10252](#)) ...

 1cc216e

[Sign up for free](#) to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

No labels

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

Code with agent mode

▼

 **Disable loading jinja2 `PromptTemplate` from file.**
langchain-ai/langchain

Participants

